

PRAHARI

prahari · “the sentinel that watches the perimeter”

AI-Driven Cyber Resilience for Critical National Infrastructure

Behavioural threat detection that fuses auth, network and end-point telemetry into one incident timeline — mapped to MITRE ATT&CK with cited reasoning, and running fully air-gapped.

Event	ET AI Hackathon 2026
Problem Statement	PS7 — Multi-Agent AI for Cyber Resilience of Critical National Infrastructure
Submission	Team Prahari
Team	Add member names here
Repository	https://github.com/Exyons/ET-GenAI-Hackathon-2
Contact	as096255@gmail.com

One-line thesis. Real machine learning does the *detection*; the local LLM only *reasons and explains*. Every automated decision traces back to the exact raw log records that triggered it — and nothing ever leaves the perimeter.

Prepared for hackathon evaluation. All benchmark figures in this document are measured on real LANL red-team data and reproducible from the repository.

Contents

1	Executive Summary	2
2	The Problem	2
2.1	Why signatures fail on national infrastructure	2
2.2	The sovereignty constraint	2
3	Solution Overview	2
3.1	Architecture at a glance	3
3.2	Agent topology → problem-statement coverage	3
4	Detection — Behaviour, Not Signatures	3
4.1	Per-entity feature engineering (UEBA)	4
4.2	Isolation Forest	4
4.3	The honest single-source finding	4
5	The Money Moment — Cross-Source Fusion	4
6	ATT&CK Attribution — Grounded RAG, Air-Gapped	5
6.1	Measured attribution of the C553 incident	6
7	Response — Recommendation Behind a Human Gate	6
8	Sovereign, Air-Gapped Deployment	6
9	Evidence — Measured and Reproducible	6
9.1	Behavioural vs. signature on real LANL red-team data	6
9.2	Cross-source fusion on the red-team host set	7
9.3	Summary scorecard	7
10	Implementation	7
10.1	Tech stack	8
10.2	At a glance	8
10.3	The SOC console	8
10.4	Threat intelligence — fresh, not stale, without full egress	8
11	Limitations and Roadmap	9
12	Why Prahari Wins	9
A	Appendix — Run It Yourself	9
A.1	Selected REST surface	10

1 Executive Summary

Critical national infrastructure — power grids, water systems, transport, defence networks — is now attacked by *advanced persistent threats* (APTs) that never trip a signature. They log in with valid stolen credentials, move laterally between internal hosts, and beacon out quietly. Each individual event looks legitimate. The attack only becomes visible when you *correlate across sensors* and read the *behaviour*.

Prahari is a multi-agent Security Operations Center (SOC) that does exactly this. It ingests authentication, process/endpoint and network telemetry into a single canonical event schema, learns a behavioural baseline *per entity*, and fuses co-occurring anomalies across all three sources into one scored incident on one host's timeline. It then maps that incident to MITRE ATT&CK techniques using a grounded, retrieval-augmented local LLM, predicts the adversary's likely next tactic, and recommends a containment action behind a human gate.

The entire system runs **air-gapped** — no cloud API, no data egress — which is the non-negotiable requirement for classified OT/IT telemetry and the differentiator no cloud-hosted SOC can match on sovereign infrastructure.

Headline result (measured on real LANL red-team logs): behavioural detection recalls **79%** of genuine red-team lateral movement where the signature/IOC baseline recalls **0%**; cross-source fusion produces **high-confidence incidents on 9 of 11** red-team hosts; ATT&CK attribution runs entirely on local models with a hallucination guard.

2 The Problem

2.1 Why signatures fail on national infrastructure

Signature and indicator-of-compromise (IOC) detection asks “have I seen this exact bad thing before?” APT tradecraft is built to defeat that question:

- **Valid credentials.** A stolen-but-legitimate NTLM login to an internal host has no malicious signature — it is a normal authentication event.
- **Living off the land.** *whoami*, *net use*, PowerShell — native tools, no malware to fingerprint.
- **Low and slow.** Steps are spread across sensors and time so no single log looks alarming.

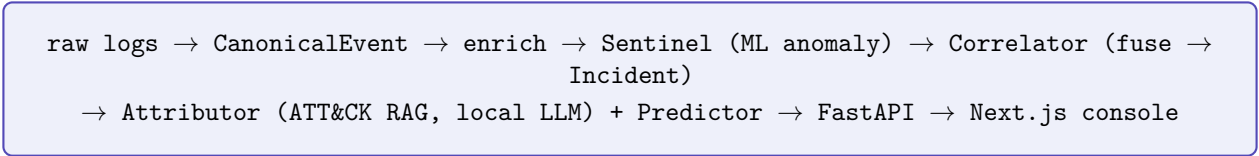
The intelligence is not in any one event; it is in the *relationship* between an anomalous login, an unusual process, and an outbound connection on the same host within a short window. Detecting that requires (a) behavioural baselining rather than rules, and (b) fusion across otherwise-siloed telemetry.

2.2 The sovereignty constraint

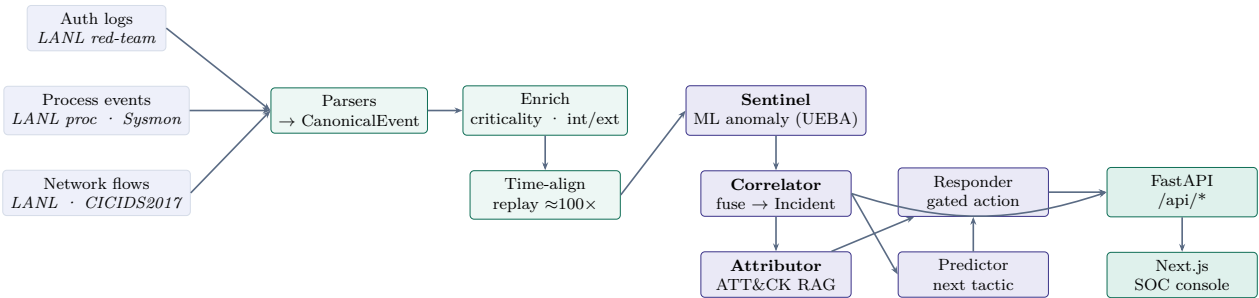
For critical national infrastructure the telemetry is classified and *legally cannot leave the operational perimeter*. That rules out every SOC product built around a cloud LLM API. A credible solution must deliver the AI reasoning **locally**.

3 Solution Overview

Prahari is organised as a deterministic ingestion spine feeding a set of cooperating agents, surfaced through a live Next.js SOC console.



3.1 Architecture at a glance



The golden rule. Everything before the Attributor is deterministic Python + scikit-learn. The LLM never decides *whether* something is an attack — it only *names* an attack the ML already found, and only from a retrieved candidate set. This keeps the system auditable and immune to LLM hallucination in the detection path.

3.2 Agent topology → problem-statement coverage

Five agents map onto the five capabilities the problem statement asks for. Three are built in depth; two are lightweight but functional — full coverage, anchored by depth where it matters.

Agent	Job	Brain	PS component
Sentinel	Per-entity behavioural baselines; scores deviations	Isolation Forest + learned novelty (UEBA)	1 · Behavioural anomaly
Correlator	Fuse multi-source events into one Incident	Deterministic kill-chain phases + compound score	Challenge core
Attributor	Map Incident to ATT&CK techniques, cited	RAG: embeddinggemma + qwen2.5 (local)	2 · APT attribution
Predictor	Likely next tactic	Markov chain over ATT&CK tactics	2 · APT prediction
Responder	Gated containment recommendation	Playbook catalogue + human triple-gate	3 · Autonomous response
Vuln view	CVE / asset criticality context	Lookup / CMDB enrichment	4 · Vuln prioritisation
Digital twin	Attack-path / lateral view	Graph view (attack map)	5 · Resilience twin

4 Detection — Behaviour, Not Signatures

Detection lives in two ML detectors: **Sentinel** (authentication) and **NetworkSentinel** (flows). This is where the “detect by behaviour” claim is earned.

4.1 Per-entity feature engineering (UEBA)

AuthBaseline learns what is normal *for each user* from history — the hosts they log into, the hosts they log in *from*, their usual authentication mechanisms, and their active hours. Each event is then reduced to five interpretable novelty signals in $[0, 1]$:

Feature	Meaning	A value of 1.0 means
<code>is_new_dest</code>	Host never seen for this user	Lateral move to a new machine
<code>is_new_src</code>	Source host never seen	Logging in from somewhere new
<code>auth_type_rarity</code>	$1 - \text{freq}(\text{auth type})$	Rare mechanism (NTLM where Kerberos is normal $\approx$ pass-the-hash)
<code>hour_novelty</code>	Active hour never seen	A 3 a.m. login
<code>dest_criticality</code>	Asset importance (0.25–1.0)	Targeting a critical host

The baseline is *learned from data*, not hand-written rules, and it is *interpretable*: an alert reads literally as “new destination + NTLM + off-hours + critical asset.”

4.2 Isolation Forest

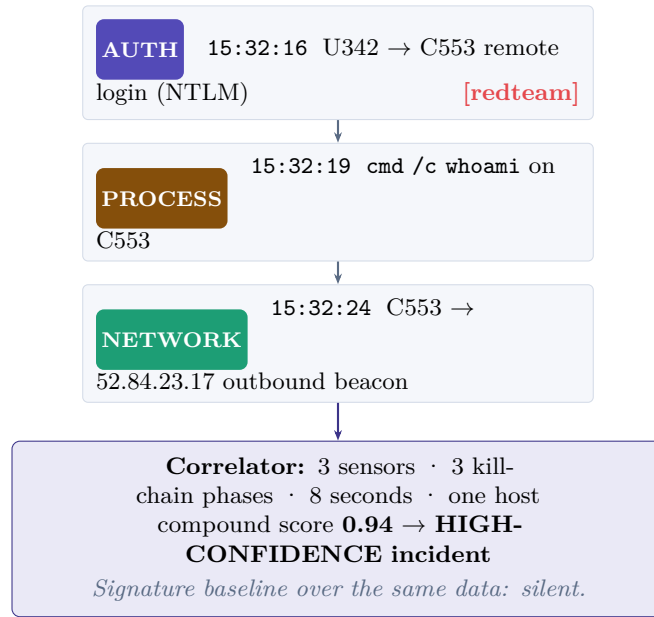
Sentinel scores each five-feature vector with an Isolation Forest: an ensemble of random trees that isolates anomalies in few splits (anomalies are “few and different”, so they separate early). The behavioural feature space means novelty — not a known-bad signature — is what drives the score. NetworkSentinel applies the same idea to flow features after `StandardScaler` normalisation.

4.3 The honest single-source finding

Measured on real LANL data, an *auth-only, per-event* novelty threshold recalls **79%** of red-team lines but at brutal precision (0.4%, $\approx 15\text{k}$ false positives) — real users constantly touch new hosts and log in at odd hours. We swept thresholds and added a compound novelty gate: neither fixes single-source precision. **This is the empirical justification for the architecture: precision is not a threshold problem, it is a fusion problem.**

5 The Money Moment — Cross-Source Fusion

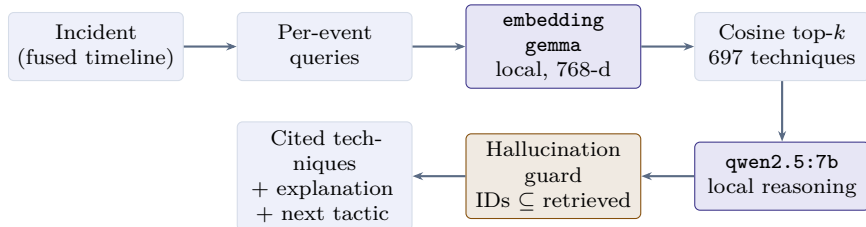
The Correlator is the heart of the system. It groups anomalous events by entity within a time window, tags each with its kill-chain phase, and computes a *compound score*. Three unremarkable events, fused on one host’s timeline, trace an intrusion no single sensor would flag:



This is verified on real data, not synthetic. On the genuine LANL red-team host set, correlating by target host fused auth + process + network into **high-confidence incidents for 9 of 11** red-team hosts — each spanning all three sources and three kill-chain phases (lateral movement + execution + command-and-control). The “C553 moment” exists in the real capture.

6 ATT&CK Attribution — Grounded RAG, Air-Gapped

Once an incident exists, the Attributor names *what* it is in MITRE ATT&CK terms — with citations, and without ever leaving the box.



- **Retrieval.** Each timeline step is embedded locally with `embeddinggemma` and matched by cosine similarity against 697 MITRE ATT&CK enterprise techniques held in memory (numpy) — no external vector database needed for ≈ 700 documents.
- **Reasoning.** `qwen2.5:7b` maps each step to techniques and writes a cited explanation. Querying *per timeline step* (not one incident-level query) is what makes lateral-movement and C2 techniques surface instead of being swamped by discovery.
- **Hallucination guard.** Any technique ID the LLM emits must be a member of the retrieved candidate set, or it is rejected. The model literally cannot invent a technique that was not grounded in retrieval.

6.1 Measured attribution of the C553 incident

Timeline step	Technique	Correct?
NTLM remote login (lateral movement)	T1021.006 Remote Services	✓ family
cmd /c whoami (discovery)	T1057 Process Discovery	✓ exact
Outbound beacon (C2)	T1071.002 App-Layer Protocol	✓ family

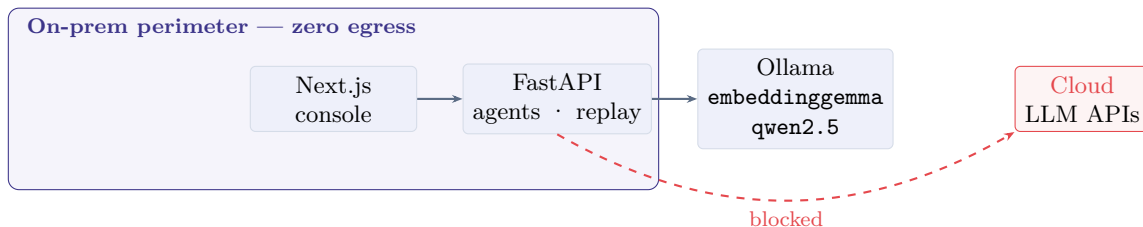
Predicted next tactic: command-and-control → exfiltration (1.0), from a Markov model over ATT&CK tactic transitions. All three cited IDs were present in the retrieved candidate set; no un-retrieved ID could be emitted.

7 Response — Recommendation Behind a Human Gate

The Responder proposes containment (e.g. `block_ip`) from a playbook catalogue that records each action’s *what* and *blast-radius impact*. It is deliberately conservative:

- **Public-only blocking.** IPs are classified as internal (RFC1918) or public; `block_ip` is only ever recommended for public destinations, so a response never proposes black-holing an internal host.
- **Dry-run by default.** Actions execute in dry-run unless explicitly armed.
- **Triple human gate.** Arm → approve → execute, each a distinct step, with a revert path. Autonomy is bounded by design; a human is always in the loop for anything that touches production.

8 Sovereign, Air-Gapped Deployment



Classified OT/IT telemetry cannot legally leave the perimeter, so Prahari runs entirely locally. `docker-compose` brings up the API, the web console and Ollama; a `SOVEREIGN_MODE` posture enforces zero egress. This is the capability no cloud-API SOC can offer on national infrastructure — and, as the attribution benchmark showed, cloud models (`qwen3.5:cloud`, 397B) returned 403 Forbidden without account sign-in, so the local path is both the fallback and the stronger story.

9 Evidence — Measured and Reproducible

Every claim below is recorded in the repository’s `docs/benchmarks/` and reproducible from the listed command.

9.1 Behavioural vs. signature on real LANL red-team data

Detector	Recall	Precision	FPR	TP / FP / FN
Sentinel (behavioural)	0.794	0.004	0.075	54 / 14,941 / 14
Signature (IOC)	0.000	0.000	0.000	0 / 0 / 68

Window $t \in [759600, 770400)$ (densest red-team burst); chronological 50/50 split; threshold at quantile 0.99. The signature baseline is structurally blind to valid-credential logins to internal hosts.

9.2 Cross-source fusion on the red-team host set

Measure	Result
Incidents formed	102
High-confidence incidents	21
... of which on red-team hosts	9
Red-team hosts fused (auth+proc+flow, 3 phases)	9 of 11

Window $t \in [150000, 160000)$, correlate by target host, 600s window. Compound score 0.80 on each fused red-team incident.

9.3 Summary scorecard

Claim	Result	Source
Behavioural vs. signature recall (real LANL)	0.79 vs 0.00	lanl-real-results.md
Real multi-source fusion	9/11 red-team hosts	lanl-multisource-results.md
Air-gapped grounded attribution	C553 $\rightarrow$ T1021.006 / T1057 / T1071.002	attribution-demo.md
Mean time to detect	weeks $\rightarrow$ $\approx$ seconds (replay)	dashboard
Auditability	every incident carries raw evidence	CanonicalEvent.raw

We report the limits honestly. The fusion benchmark pre-slices to the red-team host set, so it demonstrates that fusion *is real and forms on genuine APT hosts* — it does not yet claim precision-at-scale against the full benign population. That requires per-source anomaly models on process and flow (only auth has a behavioural model today) so that fusion combines *anomalous* signals rather than raw activity. That is the honest next lift, and it is scoped in the roadmap.

10 Implementation

10.1 Tech stack

Layer	Choice
Ingestion / replay	Python generators + timer ($\approx 100\times$), no Kafka
Detection	scikit-learn Isolation Forest + learned novelty (UEBA); StandardScaler for network
Attribution	Ollama (embeddinggemma + qwen2.5:7b) + numpy cosine retrieval
Correlation	Kill-chain tagging + compound scoring (pure Python)
Backend	FastAPI + Pydantic (async event loop; blocking LLM work off-loaded via <code>asyncio.to_thread</code>)
Frontend	Next.js 15 (App Router) + React 19 + TypeScript; live SSE + polling; light/dark theming
Collectors	Stdlib Python agents for Linux (<code>/proc</code> , journal) and Windows (Security 4624/4625, Sysmon 1/3)
Deploy	<code>docker-compose</code> · <code>SOVEREIGN_MODE</code> (zero egress)

10.2 At a glance

Backend	Frontend	REST endpoints	Tests
$\approx 7,000$ lines Python	$\approx 3,400$ lines TS/TSX	30+ <code>/api</code> routes	50+ test files

10.3 The SOC console

The Next.js console is a live operator surface, not a static report:

- **Command view** — an interactive, pan/zoom/replayable attack graph: the focus host, lateral-movement peers, public C2 endpoints, and the predicted next node.
- **Incident workspace** — a decision-queue with a “why this incident” evidence rail (raw records), the ATT&CK attribution panel with per-technique reasoning, and the gated response controls.
- **Live telemetry** — fleet health, an event tape with clickable IP enrichment, and a live-updating visual summary (stat tiles, donut by type, bars).
- **Settings** — provider selection (Ollama local / Ollama Cloud / OpenAI-compatible), model selection, blocklist management, and a light/dark theme toggle.
- **Report** — an AI situation summary with charts and an export path.

10.4 Threat intelligence — fresh, not stale, without full egress

Threat intel runs offline-first (bundled CIDR blocklist, provider and geo lookups) but can *optionally* refresh from configurable feed URLs and enrich individual IPs on demand, so local intelligence does not go stale. Operators can also set their own blocklist entries. The posture is a deliberate middle ground: air-gapped by default, with explicit, operator-controlled fetch points — never a silent, always-on egress.

11 Limitations and Roadmap

Known limitation (today)	Planned lift
Only auth has a behavioural model; proc/flow fusion uses raw activity	Per-host process baselines + full flow anomaly scoring, so fusion combines <i>flagged</i> signals → precision-at-scale
Fusion benchmark pre-slices to red-team hosts	Whole-population run separating red-team from benign hosts
Digital-twin / vuln agents are lightweight	Full attack-path graph + CVE-driven prioritisation
Single-node replay demo	Distributed ingestion for production telemetry volumes

12 Why Prahari Wins

1. **It detects what signatures cannot** — 79% recall on real red-team lateral movement where IOC detection scores 0%.
2. **The fusion is real, on real data** — the three-sensor “money moment” forms on 9 of 11 genuine LANL red-team hosts, not on synthetic examples.
3. **The AI is grounded and honest** — ML detects, the LLM only names attacks from a retrieved set behind a hallucination guard; every decision traces to raw evidence.
4. **It is sovereign by construction** — fully air-gapped, the one thing a cloud-API SOC can never be on classified national infrastructure.
5. **We measured, and we report the limits** — every headline number is reproducible, and the honest next lift is scoped rather than hidden.

A Appendix — Run It Yourself

```
# 1. Full stack (API + web + Ollama)
docker-compose up

# 2. API tests
cd apps/api && uv run pytest -v

# 3. Local LLM attribution (air-gapped)
curl -fsSL https://ollama.com/install.sh | sh
ollama pull qwen2.5:7b          # reasoning - writes the explanation
ollama pull embeddinggemma     # embeddings - powers ATTACK retrieval
ollama serve
# OLLAMA_HOST=http://localhost:11434
# PRAHARI_CHAT_MODEL=qwen2.5:7b  PRAHARI_EMBED_MODEL=embeddinggemma

# 4. Reproduce the headline benchmarks
cd apps/api
PYTHONPATH=. uv run python scripts/run_real_benchmark.py 759600 770400 400000
PYTHONPATH=. uv run python scripts/run_multisource_incident.py 150000 160000
PYTHONPATH=. uv run python scripts/run_attribution_demo.py
```

A.1 Selected REST surface

Endpoint	Purpose
GET /api/status · /summary	Live pipeline + fleet health
GET /api/events/incidents	Fused incidents
GET /api/incidents/{id}	Incident detail + attribution
GET /api/stream	SSE live event stream
GET /api/network/{ip}	IP enrichment (provider · geo · reputation)
GET/PUT /api/settings	Provider / model / theme settings
POST /api/threatintel/refresh	Optional feed refresh
GET/POST /api/actions/*	Response queue + triple gate

Repository: <https://github.com/Exyons/ET-GenAI-Hackathon-2> · Contact: as096255@gmail.com